
PROMPT MESTRE - BACKEND

Versao 1 com formulario publico proprio e banco preparado para a V2

Este arquivo substitui o prompt anterior do backend.

PROMPT MESTRE PARA O CODEX - BACKEND

Nova funcionalidade obrigatoria: criar um formulario publico proprio, servido pelo sistema, sem Google Forms, planilha intermediaria ou automacao paga. As respostas devem entrar diretamente no PostgreSQL pela API do proprio backend.

1. Escopo atual

- Desenvolver somente a Versao 1.
- Manter importacao CSV/XLSX e cadastro manual.
- Adicionar formulario publico proprio por link.
- O link sera divulgado no canal de transmissao do WhatsApp.
- Nao integrar a API Oficial do WhatsApp nesta fase.
- As quatro tabelas futuras permanecem vazias.

2. Arquitetura modular obrigatoria

- Todo o codigo fica dentro de src.
- Cada dominio fica dentro de src/modulos.
- O formulario publico possui modulo proprio em src/modulos/formularioPublico.
- Cada modulo agrupa Routes, Controller, Service, Model e Validacao.
- Nao criar pastas globais de controllers, services ou models.
- Rotas internas continuam autenticadas; rota do formulario e publica.

3. Estrutura esperada

```
backend/  
  src/  
    configuracoes/  
    erros/  
    middlewares/  
  
    modulos/  
      autenticacao/  
      usuarios/  
      bairros/  
      problemas/  
      origens/  
      contatos/  
      formularioPublico/  
        formularioPublicoRoutes.js  
        formularioPublicoController.js  
        formularioPublicoService.js  
        formularioPublicoModel.js  
        formularioPublicoValidacao.js  
      importacoes/  
      consentimentos/  
      tentativas/  
      relatorios/  
      auditoria/  
  
      utilitarios/  
      app.js  
      server.js  
  
  testes/  
    unitarios/  
    integracao/  
  
  uploads/  
  .env.example  
  .gitignore  
  package.json  
  README.md  
  STATUS_PROJETO.md
```

4. Fluxo do formulario publico

- Receber nome, telefone, bairro, problema, idade e participacao eleitoral opcional.
- Receber consentimento para armazenamento e consentimento separado para futuras mensagens.
- Nenhuma resposta de consentimento pode vir marcada por padrao.
- Consentimento para armazenamento deve ser Sim para concluir o cadastro completo.
- Normalizar telefone antes de consultar ou gravar.
- Se o telefone nao existir, criar contato com forma_entrada = formulario_publico.
- Se o telefone existir, nao duplicar; atualizar somente os campos permitidos e registrar novos consentimentos.
- Gravar contato e consentimentos na mesma transacao.
- No formulario publico, id_usuario_responsavel e id_usuario_cadastro permanecem nulos.
- Responder com mensagem publica simples, sem expor IDs internos ou estrutura do banco.

5. Seguranca da rota publica

- Rate limit especifico e mais restritivo.
- Validacao Zod rigorosa.
- Limite de tamanho do corpo da requisicao.
- Protecao por honeypot invisivel e tempo minimo de preenchimento.
- Nao registrar telefone, nome ou respostas completas nos logs.
- CORS apenas para os dominios oficiais configurados.
- SQL parametrizado e transacao.
- Mensagens de erro genericas para o publico.
- Testar repeticao, abuso, telefone invalido e payload malformado.

6. Dependencias

Dependencia	Finalidade
express	Servidor HTTP, rotas publicas e internas e middlewares.
pg	Conexao e consultas parametrizadas no PostgreSQL.
dotenv	Variaveis locais do arquivo .env.
bcrypt	Hash e comparacao segura de senhas.
jsonwebtoken	Autenticacao por JWT na area interna.
zod	Validacao de body, params e query, inclusive no formulario publico.
helmet	Cabecalhos HTTP de seguranca.
cors	Restricao das origens autorizadas.
express-rate-limit	Protecao contra abuso no login e no formulario publico.
multer	Recebimento dos arquivos CSV e XLSX.
csv-parse	Leitura de arquivos CSV.
xlsx	Leitura de planilhas XLSX.
pino / pino-http	Logs estruturados sem expor dados pessoais.
jest / supertest	Testes unitarios, de integracao e das rotas publicas.
nodemon	Reinicio automatico no desenvolvimento.

7. Comandos previstos

```
npm install express pg dotenv bcrypt jsonwebtoken zod helmet cors express-rate-limit multer csv-parse xlsx pino pino-http
npm install --save-dev jest supertest nodemon
```

8. Etapas atualizadas

- Etapa 1: fundacao modular, seguranca, AppError e testes.
- Etapa 2: conexao e verificacao das 14 tabelas.
- Etapa 3: autenticacao e usuarios.
- Etapa 4: bairros, problemas e origens.
- Etapa 5: formulario publico - endpoint, validacao, transacao e testes.
- Etapa 6: importacao CSV/XLSX.
- Etapa 7: contatos pendentes e filtros.
- Etapa 8: tentativas e lembrete.
- Etapa 9: cadastro manual, idade e consentimentos.
- Etapa 10: relatorios, auditoria e Excel.
- Etapa 11: regressao, seguranca e documentacao final.

9. Criterios obrigatorios do formulario

- Submissao valida cria ou atualiza um unico contato.
- Nunca duplica telefone normalizado.
- Nao aceita armazenamento = nao como cadastro completo.
- Registra texto, versao e horario de cada consentimento.
- Participacao eleitoral continua opcional.
- Nao coleta data de nascimento.
- Nao depende de servico de terceiros.
- Nao envia diretamente dados do navegador ao banco; sempre passa pela API.

10. Proibicoes

- Nao usar Google Forms, Typeform, planilha ou Zapier/Make.
- Nao expor credenciais do PostgreSQL no frontend.
- Nao implementar WhatsApp, chatbox ou campanhas agora.
- Nao criar codigo para as quatro tabelas futuras.

Comando inicial: comece somente pela Etapa 1. Crie a base modular em src, instale apenas o necessario, teste e pare.